COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.8 · Incident Response

Mestre CyberSec · **Aula 4.8 — Incident Response** (9:14) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: NIST: Preparation → Detection/Analysis → Containment → Eradication → Recovery → Lessons Learned. Containment FIRST (isola antes de limpar). Lessons Learned alimenta a próxima Preparation.

💡 Highlights que a prova CompTIA cobra

- Preparação → Detecção → Contenção → Erradicação → Recuperação → Lições aprendidas
- CONTAINMENT primeiro: isola a propagação ANTES de limpar
- Lessons Learned alimenta novamente a Preparação

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'isolates affected systems to prevent spread'=Containment

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.8 — Incident Response)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Plano de Resposta a Incidentes (IRP)
Conjunto documentado de procedimentos, funções e canais de comunicação usado para preparar, detectar, responder e recuperar-se de incidentes de segurança.

⚠ ***Armadilha CompTIA:*** *Preparation means creating the IRP before an incident; if the scenario says 'no plan' or 'roles undefined', the missing phase is Preparation.*

• Preparação (N/A)
Fase da resposta a incidentes em que políticas, planos, equipes, ferramentas, treinamento e canais de comunicação são estabelecidos antes de um incidente ocorrer.

⚠ ***Armadilha CompTIA:*** *Exam trigger: 'before the incident' or 'readiness' = Preparation. It feeds all later phases and is improved by Lessons Learned.*

• Detecção e Análise (N/A)
Fase que identifica possíveis incidentes de segurança, valida alertas, determina escopo e impacto e coleta evidências para confirmar se um incidente ocorreu.

⚠ ***Armadilha CompTIA:*** *Distinguish from Containment: detecting or validating an incident is Detection and Analysis; isolating systems is Containment.*

• Contenção (N/A)
Fase da resposta a incidentes que limita o dano e impede a propagação do incidente, frequentemente isolando sistemas ou segmentos de rede afetados.

⚠ ***Armadilha CompTIA:*** *Exam trigger: 'isolates affected systems to prevent spread' = Containment. CompTIA often tests that containment comes before eradication or cleaning.*

• Erradicação (N/A)
Fase que remove a causa raiz, malware, acesso do atacante ou componentes vulneráveis dos sistemas afetados após a contenção.

⚠ ***Armadilha CompTIA:*** *If the question says 'remove malware' or 'eliminate the root cause' after isolation, choose Eradication, not Containment or Recovery.*

• Recuperação (N/A)

Fase que restaura sistemas e serviços afetados para operação normal, valida a funcionalidade e monitora sinais de recorrência.

⚠️ ***Armadilha CompTIA:*** *Exam trigger: 'restore normal operations' or 'return to production' = Recovery. It follows Eradication, but containment must happen first.*

• Lições Aprendidas (N/A)

Fase de revisão pós-incidente que documenta o ocorrido, identifica lacunas e atualiza planos e procedimentos de preparação para melhorar respostas futuras.

⚠️ ***Armadilha CompTIA:*** *Exam trigger: 'after-action review' or 'improve future response' = Lessons Learned. It feeds back into Preparation.*

• Isolamento (N/A)

Ação de contenção que separa um sistema ou segmento de rede afetado de outros recursos para interromper movimento lateral ou exfiltração de dados.

⚠️ ***Armadilha CompTIA:*** *If the question asks the immediate first action after identifying active spread, choose isolation/containment before cleaning or rebooting.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

A equipe de segurança de um hospital confirma que um servidor de arquivos está criptografando documentos compartilhados com ransomware. O IRP é ativado. Qual ação a equipe deve tomar PRIMEIRO?

A) Desconectar o servidor da rede, preservando seu estado de energia.

B) Restaurar o servidor a partir do backup da noite anterior.

C) Executar uma verificação antivírus completa para remover o ransomware.

D) Reinstalar o servidor com um sistema operacional limpo.

QUESTÃO 2 · CENÁRIO DE EXAME

Um analista descobre que uma estação de trabalho se comunica com um servidor de comando e controle conhecido. O usuário ainda está conectado, e evidências voláteis podem ser necessárias para a investigação. Qual ação de contenção é MAIS apropriada?

A) Desligar a estação de trabalho imediatamente para interromper a atividade maliciosa.

B) Desabilitar a porta do switch ou desconectar o cabo de rede sem desligar o sistema operacional.

C) Excluir os arquivos suspeitos e reiniciar a estação de trabalho.

D) Formatar a estação de trabalho e reinstalar os aplicativos.

QUESTÃO 3 · CENÁRIO DE EXAME

Após a recuperação ter sido concluída e as operações normais restauradas após uma violação por phishing, o CISO pergunta por que o incidente não foi detectado mais cedo. Qual atividade deve ser realizada EM SEGUIDA de acordo com o ciclo de vida do NIST IR?

A) Contenção imediata dos servidores de e-mail afetados.

B) Erradicação completa do malware restante.

C) Revisão de lições aprendidas com as partes interessadas para atualizar regras de detecção e treinamento.

D) Validação do objetivo de ponto de recuperação.

QUESTÃO 4 · CENÁRIO DE EXAME

Uma empresa não possui um processo formal de RI. A gerência quer melhorar a preparação antes do próximo grande evento cibernético. Qual ação MELHOR apoia a fase de Preparação?

A) Comprar ferramentas forenses, mas não documentar procedimentos.

B) Aguardar um alerta antes de definir funções e caminhos de escalonamento.

C) Isolar permanentemente todos os servidores de produção da internet.

D) Realizar exercícios de simulação e atualizar o plano de resposta a incidentes com base nos resultados.

QUESTÃO 5 · CENÁRIO DE EXAME

Um SIEM gera um alerta de tráfego de saída incomum de uma estação de trabalho do setor financeiro às 2h. O analista precisa decidir se o alerta representa um incidente real e determinar seu escopo. Qual fase do NIST IR está sendo executada?

A) Preparação

B) Detecção e Análise

C) Contenção

D) Lições Aprendidas

QUESTÃO 6 · CENÁRIO DE EXAME

Uma infecção por malware foi contida em vários endpoints. A equipe remove os binários maliciosos, corrige a vulnerabilidade explorada e redefine credenciais comprometidas. Qual fase do ciclo de vida do NIST IR isso representa?

A) Recuperação

B) Preparação

C) Detecção e Análise

D) Erradicação

QUESTÃO 7 · CENÁRIO DE EXAME

Após o malware ser removido de um servidor de comércio eletrônico, a equipe restaura o servidor a partir de um backup limpo verificado, o reconecta ao balanceador de carga e o monitora de perto para reinfecção. Qual fase é esta?

A) Contenção

B) Erradicação

C) Recuperação

D) Lições Aprendidas

QUESTÃO 8 · CENÁRIO DE EXAME

Um worm está se espalhando rapidamente por uma rede interna plana. A equipe de RI identificou hosts infectados, mas não consegue remediar todos imediatamente. Qual abordagem de contenção é MAIS apropriada?

A) Excluir o worm de um host e aguardar definições do antivírus.

B) Desligar todo o data center para interromper todo o tráfego.

C) Isolar segmentos de rede ou VLANs afetados para limitar a propagação lateral.

D) Iniciar lições aprendidas enquanto o worm continua a se espalhar.

QUESTÃO 9 · CENÁRIO DE EXAME

Durante uma investigação de suspeita de roubo de propriedade intelectual, o departamento jurídico exige que as evidências forenses sejam admissíveis em tribunal. O endpoint foi isolado. O que a equipe deve fazer ANTES de reimplantar a imagem do sistema?

A) Executar a limpeza de disco para remover arquivos temporários.

B) Reinstalar o sistema operacional para remover artefatos.

C) Excluir perfis de usuário e trocar senhas.

D) Criar uma imagem forense e documentar a cadeia de custódia.

QUESTÃO 10 · CENÁRIO DE EXAME

Uma violação de banco de dados de clientes é confirmada. O plano de resposta a incidentes especifica requisitos de notificação para equipes jurídica, de conformidade e executiva. Após a contenção inicial, o que o comandante do incidente deve fazer EM SEGUIDA?

A) Publicar detalhes técnicos em redes sociais para alertar os clientes.

B) Seguir os procedimentos de comunicação e escalonamento do IRP para notificar as partes interessadas exigidas.

C) Aguardar a erradicação ser concluída antes de informar o departamento jurídico.

D) Pedir que os clientes afetados investiguem a violação por conta própria.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Desconectar o servidor da rede, preservando seu estado de energia.

O NIST IR exige contenção antes da erradicação ou recuperação. Isolar o servidor limita a propagação e preserva evidências voláteis. Restaurar, limpar com antivírus ou reinstalar antes da contenção pode permitir que o ataque continue e destruir evidências.

Questão 2: Alternativa B — Desabilitar a porta do switch ou desconectar o cabo de rede sem desligar o sistema operacional.

A contenção deve isolar o host da rede preservando evidências voláteis, como a memória RAM. Desligar a máquina destrói evidências residentes em memória. Excluir arquivos ou formatar pertence à erradicação/recuperação e deve ocorrer após contenção e análise.

Questão 3: Alternativa C — Revisão de lições aprendidas com as partes interessadas para atualizar regras de detecção e treinamento.

Lições aprendidas ocorrem após a recuperação e revisam o que aconteceu, por que a detecção atrasou e quais melhorias são necessárias. Seus resultados alimentam a Preparação, atualizando o IRP, regras de monitoramento e treinamento. Contenção e erradicação já deveriam estar concluídas.

Questão 4: Alternativa D — Realizar exercícios de simulação e atualizar o plano de resposta a incidentes com base nos resultados.

A Preparação inclui criar e manter o IRP, definir funções, estabelecer comunicações, treinar a equipe e testar por meio de exercícios. Exercícios de simulação revelam lacunas que podem ser corrigidas antes de um incidente. Ferramentas sem procedimentos ou funções indefinidas não proporcionam preparação.

Questão 5: Alternativa B — Detecção e Análise

Detecção e Análise envolve monitoramento, triagem de alertas, validação se um evento é um incidente real e determinação de escopo e impacto. A contenção começa após o incidente ser confirmado e compreendido suficientemente para agir.

Questão 6: Alternativa D — Erradicação

A Erradicação remove a causa do incidente, como malware, vulnerabilidades e credenciais comprometidas, após a contenção. A Recuperação então restaura as operações normais e monitora recorrências.

Questão 7: Alternativa C — Recuperação

A Recuperação envolve restaurar sistemas e serviços à operação normal a partir de backups confiáveis e validar que estão seguros, monitorando sinais de reinfecção. A Erradicação já ocorreu quando o malware foi removido.

Questão 8: Alternativa C — Isolar segmentos de rede ou VLANs afetados para limitar a propagação lateral.

A contenção deve limitar a propagação e, quando possível, permitir a continuidade de funções críticas. Segmentar ou isolar VLANs afetadas retarda o movimento lateral. Excluir de um host é insuficiente, desligar todo o data center é excessivamente disruptivo, e lições aprendidas ocorrem depois.

Questão 9: Alternativa D — Criar uma imagem forense e documentar a cadeia de custódia.

Antes que a erradicação ou recuperação destrua evidências, a equipe deve preservá-las por meio de uma imagem forense e manter a cadeia de custódia. Limpar, reinstalar ou excluir artefatos alteraria as evidências e prejudicaria a admissibilidade.

Questão 10: Alternativa B — Seguir os procedimentos de comunicação e escalonamento do IRP para notificar as partes interessadas exigidas.

O IRP deve definir caminhos de comunicação e escalonamento, incluindo notificação jurídica, de conformidade e executiva. Atrasar a notificação jurídica pode violar prazos regulatórios, enquanto a divulgação pública sem coordenação pode aumentar danos e riscos legais.